This is a Enriched C

User

This is a Enriched Context Generation scenario.

The following content was found in the files provided by the user.

** COMP3010 Module Handbook 2026-2027 - V2.pdf full content **

COMP3010 Security Operations & Incident Management

Coursework 1: Set Exercises – Analysis

Task:

The Set Exercises in this module are focused on undertaking and analysing several experimental based lab exercises. Within the module plan, several laboratory exercises provide a better understanding of the capability of incident detection and management tools. These include:

• Effectiveness of different network intrusion/monitoring tools

• Gathering information for an incident report

• Exploration of pcap packets for evidence

• Investigating alerts for intruders

You work as a security analyst. One day you receive the following pcap file with an intrusion incident detected. You are required to perform a detailed intrusion analysis on the provided network traffic logs. A set of questions have been prepared to aid you in your analysis. You will find them on as a quiz on the DLE. Using the answers from the questions in the quiz (separate document), write a 1000-word report on your findings, detailing the following:

• Identify the Infected System: Detect which system in the network has been compromised.

• Analyse How the Infection Occurred: Determine the method used to infect the system.

• Identify the Type of Infection: Describe what type of malware or attack caused the infection.

Important Notes:

• This is individual work and not a textbook-based exercise.

• You are expected to conduct a practical experiment, document your process, analyse the results, and produce an incident report.
• Your report should focus on the application of knowledge rather than merely presenting theoretical or textbook information. Critical analysis and thorough documentation of your investigative process are key to this assignment.

Coursework 1 Deliverables

1. Investigation Validation Exercise Students complete investigation validation questions supplied through the DLE. These act as milestones, verification checkpoints and accuracy checks. They are not the primary assessment.
2. Investigation Report Maximum 1,000 words, excluding references, evidence appendix and AI reflection appendix. The report should communicate the investigation as a coherent professional case study rather than as a list of answers.

Recommended focus What should be demonstrated
Methodology Selection and justification of appropriate investigation methods and tools.
Analysis Systematic examination of relevant artefacts and interpretation of findings.

COMP3010 Security Operations & Incident Management

Recommended focus What should be demonstrated
Findings Clear, evidence-based conclusions about the intrusion or monitoring problem.
Technical reasoning Explanation of how observations support conclusions and where uncertainty remains.
Table 3: Report sections
3. Evidence Portfolio – you may include this in a git repository and attach the link in your report.
• Screenshots and annotated tool outputs
• Packet captures and stream analysis
• IDS outputs and detection rules
• Logs, timelines and other relevant artefacts
• Use of AI logs, methodology and sample prompt/queries
• Other evidence necessary to demonstrate authentic investigation
4. Video Briefing
Maximum 5 minutes. Audience: SOC Lead, Incident Manager or Security Manager. The briefing should resemble a professional analyst briefing, focusing on the situation, key evidence, findings, implications and recommended next steps.
5. AI Reflection
Maximum 250 words. Students must critically discuss how AI was used, where it was beneficial, outputs generated, hallucinations or errors encountered, validation steps performed, and risks and

limitations of AI assistance. Any handicap in use of AI needs to be mentioned here – limited to freetier or open source.

The investigation validation exercise questions will be provided as Quiz 1 on the DLE.

Acceptable level of generative AI tool use in this coursework element
Partnered Work P1 – Generative AI tool use forms an integral part of the assessment and is compliant with the assessment brief. ☒
Table 4: Acceptable Level of generative AI use

Any use of AI in your work must be declared within your documentation. You must also include a signed Generative AI Declaration as an appendix to your submission. The declaration form can be found on DLE (or Here on the Programme Page). This form will not be included in any word count associated with this assignment.

The report must not exceed 1000 words or 10 pages (whichever shorter) excluding screenshots and references. Please note that anything exceeding the maximum number of pages will not be accessed by the markers. A Rubric will be used to assess and provide feedback. The template for this can be found below (Table 2).

Category Weight Fail (<40%) Pass (40%-49%) Merit (50-59% Merit (60-69%) Distinction (70%+)
Investigation
Validation
Exercise
15%
Limited completion or
substantial inaccuracies;
weak evidence of progress.
Most checkpoints
addressed; sufficient
evidence of engagement
and basic analytical
accuracy.
Most checkpoints accurate,
with evidence of structured
investigation; some
validation or unexplained
errors remain.
Generally accurate
checkpoints with evidence of
systematic investigation and
validation.
Highly accurate and well-

validated findings; errors are identified, explained and corrected through investigation.

Investigation Report 45%

Incomplete, unclear or largely descriptive; weak methodology and reasoning.

Coherent report with appropriate methodology, analysis and findings addressing the case study. Brief AI use logs in investigation report writing.

Clear, well-organised report with sound methodology and evidence-based findings; uncertainty and incident context are partly addressed. Elaborate AI use methodology provided for report writing.

Well-structured analysis with clear technical reasoning, interpretation and incident context. Evidence of only free tier frontier AI use for coursework for report writing.

Professional, precise and evidence-led investigation with strong reasoning, critical interpretation and awareness of uncertainty. Evidence of only open-source AI use for report writing.

Technical Evidence 25%

Little or irrelevant evidence;

				evidence does not support conclusions.
				Relevant evidence supports key findings and demonstrates practical engagement. Brief AI use logs in technical evidence curation.
				Relevant evidence supports most findings with some annotation and linkage to conclusions; selection or reproducibility is not well elaborated. Elaborate of AI methodology in technical evidence curation.
				Good selection and integration of technical evidence; artefacts are clearly connected to findings. Evidence of only free tier frontier AI use for coursework for report writing.
				Comprehensive, well-selected and well-annotated evidence demonstrating authentic, reproducible investigation. Use of AI for technical evidence curation limited to only open source models.
Professional Practice	15%			Limited SOC awareness, incident-response reasoning or professional communication; AI reflection absent or superficial.
				Adequate SOC/IR context, clear communication and a

basic critical AI reflection.
Brief AI use for professionalism.
Sound SOC/IR context and clear communication; AI reflection covers use, benefits, some validation and limitations with good elaboration provided.
Good professional judgement, incident-response reasoning, communication and meaningful AI reflection using only free-tier models.
Strong SOC awareness, defensible incident-response reasoning, professional briefing and critical reflection on responsible AI use and limited to only open source models.

Table 5: CW1 Marking Rubrics

Distinction-level work should provide a report short and simple enough for executives to skim but not lacking the detail that tech leads will require. It should also include both strategical and operational recommendations to avoid future incidents based on standards (ISO, NIST, NCSC) documents.

** end of COMP3010 Module Handbook 2026-2027 - V2.pdf **

** Draft.pdf full content **

COMP3010: Intrusion Analysis Investigation Report

1. Methodology Using Denning's Generic Intrusion Detection Model (ref), the intrusion incident was investigated on Ubuntu Linux by correlating Snort and Suricata alerts with Wireshark packets. This methodology was selected because Snort and Suricata's different rulesets and preprocessors reduce missed detections during triage, while Wireshark's full-packet decoding helps validate alerts and test hypotheses.

1.1 Triaging alerts

CW1Suricata.txt and CW1Snort.txt file logs were reviewed in the Ubuntu terminal using grep and viewed in gedit to filter for Priority:1 alerts and the internal IP address triggering alerts.

1.2 Wireshark
COMP3010CW1.pcap was opened in Wireshark on Windows. The time display format was set to UTC Date and Time of Day to standardise timestamps across security tools and avoid local timezone offsets.
Display filters were applied to isolate Dynamic Host Configuration Protocol (DHCP) traffic for host identification. HTTP requests filter (http.request) to establish the infection timeline and inspect TCP streams (Follow -> TCP Stream).

1.3 File extraction from Wireshark and hashing
In Wireshark, using File -> Export Objects -> HTTP, three files (gerv.gun, trow.exe, and wp.exe) were extracted because they triggered IDS alerts (ET CURRENT_EVENTS WinHttpRequest Downloading EXE, ET POLICY PE EXE or DLL Windows file download, and Snort [1:15306:22] FILE-EXECUTABLE Portable Executable binary file magic detected) and have binary HTTP content types (application/octet-stream and application/x-msdownload). To test whether gerv.gun was a disguised executable despite its .gun file extension, each exported file was verified as a Portable Executable (PE32) binary using the Linux 'file' command in Ubuntu terminal and hashed using 'shasum -a 256' to obtain SHA256 indicators of compromise for malware verification without executing the binaries.

1.4 Open-Source Intelligence (OSINT) Correlation
The initial HTTP GET request in Wireshark was analysed, and the destination host (matied.com), URI path (/gerv.gun), and extracted SHA256 file hashes were searched in quotation marks via Google and VirusTotal to identify published threat intelligence websites explaining the initial access vector.

2. Analysis and Findings 2.1. Infected System For executive situational awareness, a single Windows workstation on the corporate network was compromised by a trojan downloader and spambot, creating immediate risks to Confidentiality (potential credential and data exfiltration), Integrity (unauthorised binary execution), and Availability (outbound spam blacklisting). Correlating the IDS logs confirms that 192.168.1.96 (is the internal host generating the alerts in both Snort and Suricata. Filtering for DHCP packets in Wireshark, and and analysing the first DHCP packet, provides the host identification details: the IPv4 address is 192.168.1.96, the MAC address is 00:15:c5:de:c7:3b, and the hostname is FlashGordon-PC.

The operating system is confirmed to be 32-bit Microsoft Windows, as shown by outbound IP Time-to-Live (TTL) values of 128 in the Snort logs, Suricata policy alerts for ET POLICY Internet Explorer 6 in use - Significant Security Risk, the Win32; WinHttp.WinHttpRequest.5 User-Agent string, and the file command output confirming that the payloads are 32-bit Windows GUI executables (PE32 executable (GUI) Intel 80386, for MS Windows).

2.2 How the infection occured
The date and time of the infection are established by the first HTTP GET request in the

PCAP as the subsequent HTTP traffic relates to secondary payload downloads and command-and-control check-ins resulting from this initial request.

The date of infection is 27th of June 2017 at the time 13:38 UTC as 13:38:32 UTC is on the first HTTP GET request. During timeline validation, a timestamp discrepancy was identified and corrected: CW1Snort.txt logs subsequent executable downloads and alerts on 06/27 starting at 13:43:52, whereas CW1Suricata.txt timestamps the first alert (Event#3.49002) at 2017-06-28 00:14:33. Correlating the source IP (119.28.70.207) and destination IP (192.168.1.96) proved that Event#3.49002 corresponds to the exact same TCP stream (Packet 204) captured at 13:38 UTC on 27 June 2017, confirming that the Suricata timestamp reflects a local sensor timezone or PCAP replay offset rather than a separate incident.
In Wireshark, following the first TCP stream shows FlashGordon-PC sending an HTTP GET request for /gerv.gun to matied.com (119.28.70.207). Suricata alerted on this packet with ET CURRENT_EVENTS WinHttpRequest Downloading EXE. Inspecting the HTTP request headers shows the following:

An initial hypothesis was that a malicious .js file would appear in Wireshark's HTTP object list; however, investigating WinHttp.WinHttpRequest.5 User-Agent corrected this assumption and indicates that a local script executed on FlashGordon-PC to fetch the first executable. Searching the HTTP request indicators (matied.com and /gerv.gun) via OSINT matches a Japanese-language invoice malicious spam (malspam) campaign reported on 27 June 2017 at https://myonlinesecurity.co.uk/japanese-language-invoice-malspam-using-js-files-inside-zips-today/.
In this campaign, victims received Japanese-language emails containing .zip attachments. When the user extracted and opened the .js (JavaScript) file inside the .zip archive, Windows Script Host executed the script locally, which called WinHttpRequest to download gerv.gun. According to the myonlinesecurity.co.uk report and linked VirusTotal entries, the extracted .js file that probably infected FlashGordon-PC had one of two SHA256 hashes (or another closely related campaign hash):
59727ea201d94d471bdbb353b1281cca3c5bebf5305b140a3c017e52a37be702
64ae13592c5d8b289be81ebb50e054cef49b0bdf50ea92dd44ed611dd274150f
[ss]

2.3 Identify the type of infection
Based on the Snort and Suricata alerts, FlashGordon-PC was infected with a Pushdo malware variant (Win.Trojan.Pushdo / Backdoor.Win32.Pushdo.s).

Inspecting File -> Export Objects -> HTTP in Wireshark reveals three Windows executable files sent over HTTP during the infection, which were saved to disk on Ubuntu and verified using file [filename] and shasum -a 256 [filename]. All files returned PE32 executable (GUI) Intel 80386, for MS Windows.

The first executable is gerv.gun (241 kB, application/octet-stream), downloaded in Packet 204 from matied.com (119.28.70.207:80 to client port 49184), with a SHA256 hash of 0931537889c35226d00ed26962ecacb140521394279eb2ade7e9d2afcf1a7272. The second executable is trow.exe (330 kB, application/octet-stream), downloaded in Packet 656 from lounge-haarstudio.nl, with a SHA256 hash of 94a0a09ee6a21526ac34d41eabf4ba603e9a30c26e6a1dc072ff45749dfb1fe1. The third executable is wp.exe (307 kB, application/x-msdownload), downloaded in Packet 855 from vantagepointtechnologies.com (145.131.10.21:80 to client port 49190), with a SHA256 hash of 79d503165d32176842fe386d96c04fb70f6ce1c8a485837957849297e625ea48.

Following the execution of gerv.gun and the secondary payloads (trow.exe and wp.exe), FlashGordon-PC initiated a lot of traffic. Suricata recorded 823 alerts for ET TROJAN Backdoor.Win32.Pushdo.s Checkin from 192.168.1.96:49200 to 96.82.200.1:80, alongside check-ins to numerous other external IPs, which Snort corroborated with Priority 1 alerts for [1:29891:7] MALWARE-CNC Win.Trojan.Pushdo variant outbound connection. Several outbound check-ins contacted security sinkholes, triggering Suricata alerts for ETPRO TROJAN Sinkhole.tech Sinkhole Reply (144.217.254.90), ET TROJAN Connection to Fitsec Sinkhole IP (193.166.255.171), and ET TROJAN Possible Compromised Host Sinkhole (212.61.180.100). Additionally, CW1Snort.txt recorded Priority 1 alerts for outbound SMTP buffer overflow attempts on TCP port 25, confirming Pushdo's secondary role as an active spambot.

3. Technical Reasoning and Uncertainty
   The observed facts directly verified from the PCAP and IDS logs are that FlashGordon-PC sent an HTTP GET request for /gerv.gun at 13:38 UTC on 27 June 2017, downloaded three PE32 executables (gerv.gun, trow.exe, and wp.exe), and generated over 800 Win.Trojan.Pushdo C2 check-in alerts over HTTP. The interpreted evidence is that the initial compromise originated from a Japanese invoice malspam .zip attachment containing an obfuscated .js dropper; because the network-based IDS sensors only monitor traffic crossing the wire and lack host-level visibility, the .js file itself is not in the PCAP, and its local execution is inferred from the WinHttp.WinHttpRequest.5 User-Agent and OSINT correlation with the myonlinesecurity.co.uk advisory. Applying professional judgement, the sinkhole replies from Sinkhole.tech and Fitsec suggest that Pushdo was attempting to contact command-and-control servers, some of which had been taken over by defenders. However, the successful downloads of trow.exe and wp.exe show that other servers were still active, meaning the computer was likely still compromised. Finally, uncertainty remains because no host-based IDS sensors or email logs are available, so it cannot be confirmed which exact .js hash (59727ea2... or 64ae1359...) was executed on disk, which local user account opened the attachment, what persistence mechanisms were established, or if data was exfiltrated.
4. Operational and Strategic Recommendations
   Operational and strategic controls are recommended to contain the incident and prevent

recurrence in alignment with ISO 27001 and NCSC and NIST guidance. At the operational level (NIST ref), the SOC must immediately isolate FlashGordon-PC from the network, block the malicious payload and the command-and-control IP addresses (119.28.70.207, 145.131.10.21, and 96.82.200.1) in the firewall and, to prevent spambots from propagating, restrict outbound SMTP traffic. Forensic disk and memory images should be captured from FlashGordon-PC to recover the original .zip and .js malspam artefacts before reimaging the workstation. At the strategic level (ISO, NCSC ref), the organisation should deploy host-based IDS to close the gap in endpoint visibility and automate host isolation. Furthermore, Snort/Suricata should be configured in inline Intrusion Prevention System (IPS) mode to actively drop packets matching known PE32 binary download and command-and-control rules ([1:15306:22] and [1:29891:7]), email gateways should block inbound .zip attachments containing .js scripts, and outdated software flagged by Suricata (Internet Explorer 6) must be decommissioned or patched.

References

** end of Draft.pdf **

Based on the content above, please provide a response to the user query.

User query: Attached is a draft of my report and the coursework brief. Review my draft against the marking criteria in the brief for a first class grade. Provide feedback on what to improve.

Assistant

This is an excellent start. Your draft demonstrates strong technical proficiency, clear methodology, and solid incident response reasoning. You have successfully reconstructed a plausible attack chain using open-source intelligence (OSINT), packet capture analysis, and IDS log correlation.

However, to achieve a **Distinction-level grade** (70%+), we need to elevate the report from a "technical case study" to a "professional executive briefing with operational rigor." The brief explicitly states: *"Distinction-level work should provide a report short and simple enough for executives to skim but not lacking the detail that tech leads will require. It should also include both strategical and operational recommendations..."*

Below is a detailed critique based on your provided rubric (Table 5) and instructions, followed by actionable improvements.

🔍 Rubric-Based Assessment

Criteria	Your Current Level	Gap to Distinction
Investigation	✅ Likely met if quiz answers align with draft findings. Ensure all DLE milestones are	Add brief references to validation checkpoints (e.g., "Alert triage validated via Suricata ET CURRENT_EVENTS match").

Criteria	Your Current Level	Gap to Distinction
Validation (15%)	explicitly referenced in the report.	
Investigation Report (45%)	✅ Clear structure, good technical reasoning, evidence-based conclusions.	**Executive Summary missing.** Distinction requires a concise overview for non-technical leadership. Also, ensure AI usage is documented in the report writing process (not just reflection).
Technical Evidence (25%)	✅ Strong use of Wireshark exports, SHA256 hashing, OSINT correlation.	Ensure evidence portfolio links are included and annotated clearly. Add timeline visualization or network flow diagrams for executive readability.
Professional Practice (15%)	⚠️ Good SOC context, but AI reflection is limited to "brief notes."	Must explicitly discuss AI tools used in investigation, their limitations, validation steps, and risks. Ensure only free/open-source models are used as per brief.

📝 Key Areas for Improvement

1. Add an Executive Summary (Critical for Distinction)

The brief emphasizes: "*short and simple enough for executives to skim but not lacking the detail that tech leads will require.*"

- **Current:** Your report starts directly with methodology.
- **Fix:** Add a 1–2 paragraph executive summary at the top:
  - What was found? (e.g., "FlashGordon-PC compromised via malspam .zip containing JS dropper.")
  - Impact? (Trojan downloader + spambot; risk to confidentiality, integrity, availability.)
  - Immediate actions taken/recommended.
  - Strategic recommendations aligned with ISO/NIST/NCSC.

2. Strengthen AI Usage Documentation

The brief requires: "*Elaborate AI use methodology provided for report writing*" and "*Use of AI for technical evidence curation limited to only open source models.*"

- **Current:** Brief mentions in draft, but no explicit AI methodology section in the report itself.
- **Fix:** Add a short subsection in the report (e.g., "AI-Assisted Investigation Methodology"):
  - Which AI tools were used? (e.g., open-source LLMs for log parsing, pattern recognition, or drafting.)
  - How was output validated? (e.g., cross-referenced with raw PCAP packets and IDS logs.)
  - Acknowledge limitations/hallucinations encountered and how they were mitigated.

3. Enhance Technical Reasoning & Uncertainty

Your Section 3 ("Technical Reasoning and Uncertainty") is strong, but ensure it explicitly ties back to professional judgment:

- **Fix:** Add a brief statement on **defensible incident-response reasoning**:
  - Why did you assume the JS dropper was local? (Due to WinHttp.WinHttpRequest.5 User-Agent and OSINT match.)
  - What alternative explanations were considered and ruled out? (e.g., direct network exploit, phishing email with embedded payload vs. malspam attachment.)

4. Align Recommendations with Standards

You mention ISO/NIST/NCSC, but make it more specific:

- **Fix:** Explicitly map recommendations to standards:
  - *NIST SP 800-61 Rev 2:* Incident response lifecycle (preparation, detection, containment, eradication, recovery).
  - *ISO 27001 A.9.3:* Monitoring and logging; B.2.12: Risk treatment.
  - *NCSC Advice on Ransomware/Malware:* User awareness, email filtering, patch management.

5. Check Word Count & Formatting

- **Limit:** 1,000 words excluding references, evidence appendix, and AI reflection appendix.
- **Fix:** Ensure your report is concise. Remove redundant descriptions of tools (e.g., "Wireshark was opened on Windows" → "Wireshark analysis was performed on the PCAP file."). Use bullet points or tables for recommendations to enhance readability for executives.

6. AI Reflection Appendix

Ensure this is a separate document/appendix with:

- Tools used (open-source only).
- Prompts/query examples.
- Validation steps taken.
- Risks/limitations discussed.
- Any handicaps or workarounds.

✅ Final Checklist Before Submission

- [ ] Executive summary added (1–2 paragraphs)
- [ ] AI methodology documented in report + separate reflection appendix
- [ ] Recommendations explicitly mapped to ISO/NIST/NCSC standards

- [ ] Word count ≤ 1,000 (excluding references and appendices)
- [ ] Evidence portfolio linked and annotated
- [ ] All DLE validation checkpoints referenced or verified
- [ ] Generative AI Declaration signed and included as appendix
- [ ] No use of paid AI tools; only free/open-source models cited

---

💡 Recommended Structural Enhancement

Consider reorganizing your report slightly for executive readability:

1. **Executive Summary** (What, Impact, Immediate Actions)
2. **Incident Timeline & Technical Findings** (Infected system, infection method, malware type)
3. **Methodology & Evidence** (Tools used, key artefacts, validation steps)
4. **Operational & Strategic Recommendations** (Aligned with standards)
5. **AI-Assisted Investigation Methodology** (Brief section in report + full reflection appendix)

🎯 Final Verdict

Your draft is already strong and likely on track for a **Merit or high Pass**. To reach **Distinction**, focus on:

- Executive readability + concise executive summary
- Explicit AI methodology documentation
- Standard-aligned recommendations
- Strict adherence to word count and AI declaration requirements

If you'd like, I can help you refine the executive summary or draft the AI reflection section based on your actual tool usage. Just let me know!